VULNERA

Gestão de análises de segurança

Relatório SAST/SCA

Pentest API — Integração B2B

EMPRESA

API B2B Integração

APLICAÇÃO

Semgrep OSS 1.184.0 · SARIF

GERADO EM

13/11/2026 às 07:49

Importação do arquivo nodegoat-semgrep-v2.sarif por Bruno Pentester em 13/11/2026, 07:49.

Documento confidencial — uso restrito às partes envolvidas na análise.

Sumário executivo

A análise de código gerada por Semgrep OSS 1.184.0 trouxe 29 achados para o projeto Pentest API — Integração B2B. Restam 29, dos quais 4 de severidade crítica ou alta.

29	4	0	6
Achados no relatório	Críticos + altos	Novos desde a anterior	Resolvidos

Distribuição por severidade

Triagem e origem

Por triar: 28 · Confirmado: 0 · Falso-positivo: 0 · Risco aceito: 1

Código-fonte (SAST): 29 · Dependências (SCA): 0 · Já promovidos a vulnerabilidade: 0

Comparação com a importação anterior

Novos: 0 · Continuam: 29 · Resolvidos (sumiram do relatório): 6. Um achado resolvido não está necessariamente corrigido: pode ter saído do escopo da análise. Os que já eram vulnerabilidades devem ser retestados antes de serem fechados.

- [Alta] Found data from an Express or Next web request flowing to `eval`. — /src/app/routes/contributions.js:32 (vulnerabilidade registrada: retestar)
- [Alta] Found data from an Express or Next web request flowing to `eval`. — /src/app/routes/contributions.js:34
- [Alta] Found data from an Express or Next web request flowing to `eval`. — /src/app/routes/contributions.js:33
- [Média] Detected the use of eval(). — /src/app/routes/contributions.js:33
- [Média] Detected the use of eval(). — /src/app/routes/contributions.js:32
- [Média] Detected the use of eval(). — /src/app/routes/contributions.js:34

Achados por severidade

Alta

1. Private Key detected.

Código-fonte (SAST) · Regra generic.secrets.security.detected-private-key.detected-private-key · CWE-798 · Triagem: Por triar

LOCAL
/src/artifacts/cert/server.key:1

DESCRIÇÃO
Private Key detected. This is a sensitive credential and should not be hardcoded here. Instead, store this in a separate, private file.

RECOMENDAÇÃO
Private Key detected. This is a sensitive credential and should not be hardcoded here. Instead, store this in a separate, private file. #### ? Enable cross-file analysis and Pro rules for free at sg.run/pro References: - [Semgrep Rule](https://semgrep.dev/r/generic.secrets.security.detected-private-key.detected-private-key) - [https://owasp.org/Top10/A07_2021-Identification_and_Authentication_Failures](https://owasp.org/Top10/A07_2021-Identification_

TRECHO
-----BEGIN RSA PRIVATE KEY-----
MIICXgIBAAKBgQCfn8uP4FuHaaAPrMkcl1fNMQM5EGMT4nnNSVoaEVdiDLc6P0mC

REFERÊNCIA
https://semgrep.dev/r/generic.secrets.security.detected-private-key.detected-private-key

---

Alta

2. bcrypt hash detected

Código-fonte (SAST) · Regra generic.secrets.security.detected-bcrypt-hash.detected-bcrypt-hash · CWE-798 · Triagem: Por triar

LOCAL
/src/artifacts/db-reset.js:19

DESCRIÇÃO
bcrypt hash detected

RECOMENDAÇÃO
bcrypt hash detected #### ? Enable cross-file analysis and Pro rules for free at sg.run/pro References: - [Semgrep Rule](https://semgrep.dev/r/generic.secrets.security.detected-bcrypt-hash.detected-bcrypt-hash) - [https://owasp.org/Top10/A07_2021-Identification_and_Authentication_Failures](https://owasp.org/Top10/A07_2021-Identification_

TRECHO
//"password" : "$2a$10$8Zo/1e8KM8QzqOKqbDlYlONBOzukWXrM.IiyzqHRYDXqwB3gzDsba", // Admin_123

REFERÊNCIA
https://semgrep.dev/r/generic.secrets.security.detected-bcrypt-hash.detected-bcrypt-hash

Alta

3. bcrypt hash detected

Código-fonte (SAST) · Regra generic.secrets.security.detected-bcrypt-hash.detected-bcrypt-hash · CWE-798 · Triagem: Por triar

LOCAL
/src/artifacts/db-reset.js:28

DESCRIÇÃO
bcrypt hash detected

RECOMENDAÇÃO
bcrypt hash detected #### ? Enable cross-file analysis and Pro rules for free at sg.run/pro References: - [Semgrep Rule](https://semgrep.dev/r/generic.secrets.security.detected-bcrypt-hash.detected-bcrypt-hash) - [https://owasp.org/Top10/A07_2021-Identification_and_Authentication_Failures](https://owasp.org/Top10/A07_2021-Identification_

TRECHO
// "password" : "$2a$10$RNFhiNmt2TTpVO9cqZElb.LQM9e1mzDoggEHufLjAnAKImc6FNE86",// User1_123

REFERÊNCIA
https://semgrep.dev/r/generic.secrets.security.detected-bcrypt-hash.detected-bcrypt-hash

Alta

4. bcrypt hash detected

Código-fonte (SAST) · Regra generic.secrets.security.detected-bcrypt-hash.detected-bcrypt-hash · CWE-798 · Triagem: Por triar

LOCAL
/src/artifacts/db-reset.js:36

DESCRIÇÃO
bcrypt hash detected

RECOMENDAÇÃO
bcrypt hash detected #### ? Enable cross-file analysis and Pro rules for free at sg.run/pro References: - [Semgrep Rule](https://semgrep.dev/r/generic.secrets.security.detected-bcrypt-hash.detected-bcrypt-hash) - [https://owasp.org/Top10/A07_2021-Identification_and_Authentication_Failures](https://owasp.org/Top10/A07_2021-Identification_

TRECHO
//"password" : "$2a$10$Tlx2cNv15M0Aia7wyItjsepeA8Y6PyBYaNdQqvpxkIUlcONf1ZHyq", // User2_123

REFERÊNCIA
https://semgrep.dev/r/generic.secrets.security.detected-bcrypt-hash.detected-bcrypt-hash

Média

5. GitHub Actions step uses a mutable tag or branch reference.

Código-fonte (SAST) · Regra
yaml.github-actions.security.github-actions-mutable-action-tag.github-actions-mutable-action-tag · CWE-1357 · Triagem: Risco aceito

LOCAL
/src/.github/workflows/e2e-test.yml:16

DESCRIÇÃO
GitHub Actions step uses a mutable tag or branch reference. Tags and branch names can be silently repointed by the action owner, enabling supply-chain attacks — as seen in the trivy-action and kics-github-action compromises. Pin the reference to a full 40-character commit SHA instead, e.g. `uses: actions/checkout@8ade135a41bc03ea155e62e844d188df1ea18608`.

RECOMENDAÇÃO
GitHub Actions step uses a mutable tag or branch reference. Tags and branch names can be silently repointed by the action owner, enabling supply-chain attacks — as seen in the trivy-action and kics-github-action compromises. Pin the reference to a full 40-character commit SHA instead, e.g. `uses: actions/checkout@8ade135a41bc03ea155e62e844d188df1ea18608`. #### ? Enable cross-file analysis and Pro rules for free at sg.run/pro References: - [Semgrep Rule](https://semgrep.dev/r/yaml.github-actions.security.github-actions-mutable-action-tag.github-actions-mutable-action-tag) - [https://docs.github.com/en/actions/security-guides/security-hardening-for-github-actions#using-third-party-actions](https://docs.gitl
(texto completo no Vulnera)

TRECHO
uses: actions/checkout@v2

NOTA DA TRIAGEM
Ações oficiais do GitHub; fixar por SHA entra no próximo ciclo.

REFERÊNCIA
https://semgrep.dev/r/yaml.github-actions.security.github-actions-mutable-action-tag.github-actions-mutable-action-tag

Média

6. GitHub Actions step uses a mutable tag or branch reference.

Código-fonte (SAST) · Regra
yaml.github-actions.security.github-actions-mutable-action-tag.github-actions-mutable-action-tag · CWE-1357 · Triagem: Por triar

LOCAL
/src/.github/workflows/e2e-test.yml:21

DESCRIÇÃO
GitHub Actions step uses a mutable tag or branch reference. Tags and branch names can be silently repointed by the action owner, enabling supply-chain attacks — as seen in the trivy-action and kics-github-action compromises. Pin the reference to a full 40-character commit SHA instead, e.g. `uses: actions/checkout@8ade135a41bc03ea155e62e844d188df1ea18608`.

RECOMENDAÇÃO
GitHub Actions step uses a mutable tag or branch reference. Tags and branch names can be silently repointed by the action owner, enabling supply-chain attacks — as seen in the trivy-action and kics-github-action compromises. Pin the reference to a full 40-character commit SHA instead, e.g. `uses: actions/checkout@8ade135a41bc03ea155e62e844d188df1ea18608`. #### ? Enable cross-file analysis and Pro rules for free at sg.run/pro References: - [Semgrep Rule](https://semgrep.dev/r/yaml.github-actions.security.github-actions-mutable-action-tag.github-actions-mutable-action-tag) - [https://docs.github.com/en/actions/security-guides/security-hardening-for-github-actions#using-third-party-actions](https://docs.gith
(texto completo no Vulnera)

TRECHO
uses: actions/setup-node@v1

REFERÊNCIA
https://semgrep.dev/r/yaml.github-actions.security.github-actions-mutable-action-tag.github-actions-mutable-action-tag

---

Média

7. GitHub Actions step uses a mutable tag or branch reference.

Código-fonte (SAST) · Regra yaml.github-actions.security.github-actions-mutable-action-tag.github-actions-mutable-action-tag · CWE-1357 · Triagem: Por triar

LOCAL
/src/.github/workflows/e2e-test.yml:26

DESCRIÇÃO
GitHub Actions step uses a mutable tag or branch reference. Tags and branch names can be silently repointed by the action owner, enabling supply-chain attacks — as seen in the trivy-action and kics-github-action compromises. Pin the reference to a full 40-character commit SHA instead, e.g. `uses: actions/checkout@8ade135a41bc03ea155e62e844d188df1ea18608`.

RECOMENDAÇÃO
GitHub Actions step uses a mutable tag or branch reference. Tags and branch names can be silently repointed by the action owner, enabling supply-chain attacks — as seen in the trivy-action and kics-github-action compromises. Pin the reference to a full 40-character commit SHA instead, e.g. `uses: actions/checkout@8ade135a41bc03ea155e62e844d188df1ea18608`. #### ? Enable cross-file analysis and Pro rules for free at sg.run/pro References: - [Semgrep Rule](https://semgrep.dev/r/yaml.github-actions.security.github-actions-mutable-action-tag.github-actions-mutable-action-tag) -

[https://docs.github.com/en/actions/security-guides/security-hardening-for-github-actions#using-third-party-actions](https://docs.git
(texto completo no Vulnera)

TRECHO
uses: actions/cache@v2

REFERÊNCIA
https://semgrep.dev/r/yaml.github-actions.security.github-actions-mutable-action-tag.github-actions-mutable-action-tag

---

Média

8. GitHub Actions step uses a mutable tag or branch reference.

Código-fonte (SAST) · Regra
yaml.github-actions.security.github-actions-mutable-action-tag.github-actions-mutable-action-tag · CWE-1357 · Triagem: Por triar

LOCAL
/src/.github/workflows/e2e-test.yml:58

DESCRIÇÃO
GitHub Actions step uses a mutable tag or branch reference. Tags and branch names can be silently repointed by the action owner, enabling supply-chain attacks — as seen in the trivy-action and kics-github-action compromises. Pin the reference to a full 40-character commit SHA instead, e.g. `uses: actions/checkout@8ade135a41bc03ea155e62e844d188df1ea18608`.

RECOMENDAÇÃO
GitHub Actions step uses a mutable tag or branch reference. Tags and branch names can be silently repointed by the action owner, enabling supply-chain attacks — as seen in the trivy-action and kics-github-action compromises. Pin the reference to a full 40-character commit SHA instead, e.g. `uses: actions/checkout@8ade135a41bc03ea155e62e844d188df1ea18608`. #### ? Enable cross-file analysis and Pro rules for free at sg.run/pro References: - [Semgrep Rule](https://semgrep.dev/r/yaml.github-actions.security.github-actions-mutable-action-tag.github-actions-mutable-action-tag) - [https://docs.github.com/en/actions/security-guides/security-hardening-for-github-actions#using-third-party-actions](https://docs.git
(texto completo no Vulnera)

TRECHO
uses: actions/upload-artifact@v2

REFERÊNCIA
https://semgrep.dev/r/yaml.github-actions.security.github-actions-mutable-action-tag.github-actions-mutable-action-tag

---

Média

9. GitHub Actions step uses a mutable tag or branch reference.

Código-fonte (SAST) · Regra
yaml.github-actions.security.github-actions-mutable-action-tag.github-actions-mutable-action-tag · CWE-1357 · Triagem: Por triar

LOCAL
/src/.github/workflows/lint.yml:16

DESCRIÇÃO
GitHub Actions step uses a mutable tag or branch reference. Tags and branch names can be silently repointed by the action owner, enabling supply-chain attacks — as seen in the trivy-action and kics-github-action compromises. Pin the reference to a full 40-character commit SHA instead, e.g. `uses: actions/checkout@8ade135a41bc03ea155e62e844d188df1ea18608`.

RECOMENDAÇÃO
GitHub Actions step uses a mutable tag or branch reference. Tags and branch names can be silently repointed by the action owner, enabling supply-chain attacks — as seen in the trivy-action and kics-github-action compromises. Pin the reference to a full 40-character commit SHA instead, e.g. `uses: actions/checkout@8ade135a41bc03ea155e62e844d188df1ea18608`. #### ? Enable cross-file analysis and Pro rules for free at sg.run/pro References: - [Semgrep Rule](https://semgrep.dev/r/yaml.github-actions.security.github-actions-mutable-action-tag.github-actions-mutable-action-tag) - [https://docs.github.com/en/actions/security-guides/security-hardening-for-github-actions#using-third-party-actions](https://docs.gith
(texto completo no Vulnera)

TRECHO
uses: actions/checkout@v2

REFERÊNCIA
https://semgrep.dev/r/yaml.github-actions.security.github-actions-mutable-action-tag.github-actions-mutable-action-tag

---

Média

10. GitHub Actions step uses a mutable tag or branch reference.

Código-fonte (SAST) · Regra yaml.github-actions.security.github-actions-mutable-action-tag.github-actions-mutable-action-tag · CWE-1357 · Triagem: Por triar

LOCAL
/src/.github/workflows/lint.yml:21

DESCRIÇÃO
GitHub Actions step uses a mutable tag or branch reference. Tags and branch names can be silently repointed by the action owner, enabling supply-chain attacks — as seen in the trivy-action and kics-github-action compromises. Pin the reference to a full 40-character commit SHA instead, e.g. `uses: actions/checkout@8ade135a41bc03ea155e62e844d188df1ea18608`.

RECOMENDAÇÃO
GitHub Actions step uses a mutable tag or branch reference. Tags and branch names can be silently repointed by the action owner, enabling supply-chain attacks — as seen in the trivy-action and kics-github-action compromises. Pin the reference to a full 40-character commit SHA instead, e.g. `uses: actions/checkout@8ade135a41bc03ea155e62e844d188df1ea18608`. #### ? Enable cross-file analysis and Pro rules for free at sg.run/pro References: - [Semgrep Rule](https://semgrep.dev/r/yaml.github-actions.security.github-actions-mutable-action-tag.github-actions-mutable-action-tag) -

[https://docs.github.com/en/actions/security-guides/security-hardening-for-github-actions#using-third-party-actions](https://docs.git
(texto completo no Vulnera)

TRECHO
uses: actions/setup-node@v1

REFERÊNCIA
https://semgrep.dev/r/yaml.github-actions.security.github-actions-mutable-action-tag.github-actions-mutable-action-tag

---

Média

11. The application redirects to a URL specified by user-supplied input `req` that is not validated.

Código-fonte (SAST) · Regra javascript.express.security.audit.express-open-redirect.express-open-redirect · CWE-601 · Triagem: Por triar

LOCAL
/src/app/routes/index.js:72

DESCRIÇÃO
The application redirects to a URL specified by user-supplied input `req` that is not validated. This could redirect users to malicious locations. Consider using an allow-list approach to validate URLs, or warn users they are being redirected to a third-party website. The application redirects to a URL specified by user-supplied input `$REQ` that is not validated. This could redirect users to malicious locations. Consider using an allow-list approach to validate URLs, or warn users they are being redirected to a third-party website.

RECOMENDAÇÃO
The application redirects to a URL specified by user-supplied input `$REQ` that is not validated. This could redirect users to malicious locations. Consider using an allow-list approach to validate URLs, or warn users they are being redirected to a third-party website. #### ? Enable cross-file analysis and Pro rules for free at sg.run/pro References: - [Semgrep Rule](https://semgrep.dev/r/javascript.express.security.audit.express-open-redirect.express-open-redirect) - [https://cheatsheetseries.owasp.org/cheatsheets/Unvalidated_Redirects_and_Forwards_Cheat_Sheet.html](https://cheatsheetseri

TRECHO
return res.redirect(req.query.url);

REFERÊNCIA
https://semgrep.dev/r/javascript.express.security.audit.express-open-redirect.express-open-redirect

---

Média

12. Manually-created forms in django templates should specify a csrf_token to prevent CSRF attacks.

Código-fonte (SAST) · Regra python.django.security.django-no-csrf-token.django-no-csrf-token · CWE-352 · Triagem: Por triar

LOCAL
/src/app/views/benefits.html:54

DESCRIÇÃO
Manually-created forms in django templates should specify a csrf_token to prevent CSRF attacks.

RECOMENDAÇÃO
Manually-created forms in django templates should specify a csrf_token to prevent CSRF attacks. #### ? Enable cross-file analysis and Pro rules for free at sg.run/pro References: - [Semgrep Rule](https://semgrep.dev/r/python.django.security.django-no-csrf-token.django-no-csrf-token) - https://docs.djangoproject.com/en/4.2/howto/csrf/

TRECHO
<form method="POST" action="/benefits"> <input type="hidden" name="userId" value="{{user._id.toString()}}"></input> <input type="date" class="form-control" name="benefitStartDate" value="{{user.benefitStartDate}}"></input> <button type="submit" class="btn btn-default">Save</button> </d… (texto completo no Vulnera)

REFERÊNCIA
https://semgrep.dev/r/python.django.security.django-no-csrf-token.django-no-csrf-token

---

Média

13. Manually-created forms in django templates should specify a csrf_token to prevent CSRF attacks.

Código-fonte (SAST) · Regra python.django.security.django-no-csrf-token.django-no-csrf-token · CWE-352 · Triagem: Por triar

LOCAL
/src/app/views/login.html:107

DESCRIÇÃO
Manually-created forms in django templates should specify a csrf_token to prevent CSRF attacks.

RECOMENDAÇÃO
Manually-created forms in django templates should specify a csrf_token to prevent CSRF attacks. #### ? Enable cross-file analysis and Pro rules for free at sg.run/pro References: - [Semgrep Rule](https://semgrep.dev/r/python.django.security.django-no-csrf-token.django-no-csrf-token) - https://docs.djangoproject.com/en/4.2/howto/csrf/

TRECHO
<form method="post" role="form" method="post" id="loginform"> <label for="userName">User Name</label> <input type="text" class="form-control" id="userName" name="userName" value="{{userName}}" placeholder="Enter User Name">   <label for="password">Password</label> <input type="password" class="form-con… (texto completo no Vulnera)

REFERÊNCIA
https://semgrep.dev/r/python.django.security.django-no-csrf-token.django-no-csrf-token

---

Média

14. Manually-created forms in django templates should specify a csrf_token to prevent CSRF attacks.

Código-fonte (SAST) · Regra python.django.security.django-no-csrf-token.django-no-csrf-token · CWE-352 · Triagem: Por triar

LOCAL
/src/app/views/memos.html:15

DESCRIÇÃO
Manually-created forms in django templates should specify a csrf_token to prevent CSRF attacks.

RECOMENDAÇÃO
Manually-created forms in django templates should specify a csrf_token to prevent CSRF attacks. #### ? Enable cross-file analysis and Pro rules for free at sg.run/pro References: - [Semgrep Rule](https://semgrep.dev/r/python.django.security.django-no-csrf-token.django-no-csrf-token) - https://docs.djangoproject.com/en/4.2/howto/csrf/

TRECHO
<form action="/memos" method="post" role="search"> <textarea class="form-control" name="memo"></textarea> You may use Markdown syntax to format your memo <button type="submit" class="btn btn-primary">Submit</button> </form>

REFERÊNCIA
https://semgrep.dev/r/python.django.security.django-no-csrf-token.django-no-csrf-token

---

Média

15. This link points to a plaintext HTTP URL.

Código-fonte (SAST) · Regra html.security.plaintext-http-link.plaintext-http-link · CWE-319 · Triagem: Por triar

LOCAL
/src/app/views/tutorial/a2.html:207

DESCRIÇÃO
This link points to a plaintext HTTP URL. Prefer an encrypted HTTPS URL if possible.

RECOMENDAÇÃO
This link points to a plaintext HTTP URL. Prefer an encrypted HTTPS URL if possible. #### ? Enable cross-file analysis and Pro rules for free at sg.run/pro References: - [Semgrep Rule](https://semgrep.dev/r/html.security.plaintext-http-link.plaintext-http-link) - https://cwe.mitre.org/data/definitions/319.html

TRECHO
Seven Web Server HTTP Headers that Improve Web Application Security for Free

REFERÊNCIA
https://semgrep.dev/r/html.security.plaintext-http-link.plaintext-http-link

Média

16. This link points to a plaintext HTTP URL.

Código-fonte (SAST) · Regra html.security.plaintext-http-link.plaintext-http-link · CWE-319 · Triagem: Por triar

LOCAL
/src/app/views/tutorial/a2.html:209

DESCRIÇÃO
This link points to a plaintext HTTP URL. Prefer an encrypted HTTPS URL if possible.

RECOMENDAÇÃO
This link points to a plaintext HTTP URL. Prefer an encrypted HTTPS URL if possible. #### ? Enable cross-file analysis and Pro rules for free at sg.run/pro References: - [Semgrep Rule](https://semgrep.dev/r/html.security.plaintext-http-link.plaintext-http-link) - https://cwe.mitre.org/data/definitions/319.html

TRECHO
Passport authentication middleware

REFERÊNCIA
https://semgrep.dev/r/html.security.plaintext-http-link.plaintext-http-link

Média

17. This link points to a plaintext HTTP URL.

Código-fonte (SAST) · Regra html.security.plaintext-http-link.plaintext-http-link · CWE-319 · Triagem: Por triar

LOCAL
/src/app/views/tutorial/a2.html:210

DESCRIÇÃO
This link points to a plaintext HTTP URL. Prefer an encrypted HTTPS URL if possible.

RECOMENDAÇÃO
This link points to a plaintext HTTP URL. Prefer an encrypted HTTPS URL if possible. #### ? Enable cross-file analysis and Pro rules for free at sg.run/pro References: - [Semgrep Rule](https://semgrep.dev/r/html.security.plaintext-http-link.plaintext-http-link) - https://cwe.mitre.org/data/definitions/319.html

TRECHO
CWE-384: Session Fixation

REFERÊNCIA
https://semgrep.dev/r/html.security.plaintext-http-link.plaintext-http-link

Média

18. This link points to a plaintext HTTP URL.

Código-fonte (SAST) · Regra html.security.plaintext-http-link.plaintext-http-link · CWE-319 · Triagem: Por triar

LOCAL
/src/app/views/tutorial/a5.html:50

DESCRIÇÃO
This link points to a plaintext HTTP URL. Prefer an encrypted HTTPS URL if possible.

RECOMENDAÇÃO
This link points to a plaintext HTTP URL. Prefer an encrypted HTTPS URL if possible. #### ? Enable cross-file analysis and Pro rules for free at sg.run/pro References: - [Semgrep Rule](https://semgrep.dev/r/html.security.plaintext-http-link.plaintext-http-link) - https://cwe.mitre.org/data/definitions/319.html

TRECHO
Use latest stable version of node.js and express (or other web framework you are using). Keep a watch on published vulnerabilities of these. The vulnerabilities for node.js and express.js can be found here and

REFERÊNCIA
https://semgrep.dev/r/html.security.plaintext-http-link.plaintext-http-link

Média

19. This link points to a plaintext HTTP URL.

Código-fonte (SAST) · Regra html.security.plaintext-http-link.plaintext-http-link · CWE-319 · Triagem: Por triar

LOCAL
/src/app/views/tutorial/a5.html:51

DESCRIÇÃO
This link points to a plaintext HTTP URL. Prefer an encrypted HTTPS URL if possible.

RECOMENDAÇÃO
This link points to a plaintext HTTP URL. Prefer an encrypted HTTPS URL if possible. #### ? Enable cross-file analysis and Pro rules for free at sg.run/pro References: - [Semgrep Rule](https://semgrep.dev/r/html.security.plaintext-http-link.plaintext-http-link) - https://cwe.mitre.org/data/definitions/319.html

TRECHO
here, respectively.

REFERÊNCIA
https://semgrep.dev/r/html.security.plaintext-http-link.plaintext-http-link

Média

20. Service 'mongo' is running with a writable root filesystem.

Código-fonte (SAST) · Regra yaml.docker-compose.security.writable-filesystem-service.writable-filesystem-service · CWE-732 · Triagem: Por triar

LOCAL
/src/docker-compose.yml:13

DESCRIÇÃO
Service 'mongo' is running with a writable root filesystem. This may allow malicious applications to download and run additional payloads, or modify container files. If an application inside a container has to save something temporarily consider using a tmpfs. Add 'read_only: true' to this service to prevent this. Service '$SERVICE' is running with a writable root filesystem. This may allow malicious applications to download and run additional payloads, or modify container files. If an application inside a container has to save something temporarily consider using a tmpfs. Add 'read_only: true' to this service to prevent this.

RECOMENDAÇÃO
Service '$SERVICE' is running with a writable root filesystem. This may allow malicious applications to download and run additional payloads, or modify container files. If an application inside a container has to save something temporarily consider using a tmpfs. Add 'read_only: true' to this service to prevent this. #### ? Enable cross-file analysis and Pro rules for free at sg.run/pro References: - [Semgrep Rule](https://semgrep.dev/r/yaml.docker-compose.security.writable-filesystem-service.writable-filesystem-service) - [https://docs.docker.com/compose/compose-file/compose-file-v3/#domainname-hostname-ipc-mac_address-privileged-read_only- (texto completo no Vulnera)

TRECHO
mongo:

REFERÊNCIA
https://semgrep.dev/r/yaml.docker-compose.security.writable-filesystem-service.writable-filesystem-service

Média

21. Service 'mongo' allows for privilege escalation via setuid or setgid binaries.

Código-fonte (SAST) · Regra yaml.docker-compose.security.no-new-privileges.no-new-privileges · CWE-732 · Triagem: Por triar

LOCAL
/src/docker-compose.yml:13

DESCRIÇÃO
Service 'mongo' allows for privilege escalation via setuid or setgid binaries. Add 'no-new-privileges:true' in 'security_opt' to prevent this. Service '$SERVICE' allows for privilege escalation via setuid or setgid binaries. Add 'no-new-privileges:true' in 'security_opt' to prevent this.

RECOMENDAÇÃO
Service '$SERVICE' allows for privilege escalation via setuid or setgid binaries. Add 'no-new-privileges:true' in 'security_opt' to prevent this. #### ? Enable cross-file analysis and Pro rules for free at <a

href='https://sg.run/pro'>sg.run/pro References: - [Semgrep Rule](https://semgrep.dev/r/yaml.docker-compose.security.no-new-privileges.no-new-privileges) - [https://raesene.github.io/blog/2019/06/01/docker-capabilities-and-no-new-privs/](https://raesene.github.io/blog/2019/06/01/docker- - [https://www.kernel.org/doc/Documentation/prctl/no_new_privs.txt](https://www.kernel.org/doc/Documentation/prctl/no_new_privs.t - [https://cheatsheetseries.owasp.org/cheatsheets/Docker_Security_Cheat_Sheet.html#rule-4-add-no-new-privileges-flag](ht… (texto completo no Vulnera)

TRECHO
mongo:

REFERÊNCIA
https://semgrep.dev/r/yaml.docker-compose.security.no-new-privileges.no-new-privileges

---

Média

22. Default session middleware settings: `expires` not set.

Código-fonte (SAST) · Regra javascript.express.security.audit.express-cookie-settings.express-cookie-session-no-expires · CWE-522 · Triagem: Por triar

LOCAL
/src/server.js:78

DESCRIÇÃO
Default session middleware settings: `expires` not set. Use it to set expiration date for persistent cookies.

RECOMENDAÇÃO
Default session middleware settings: `expires` not set. Use it to set expiration date for persistent cookies. #### ? Enable cross-file analysis and Pro rules for free at sg.run/pro References: - [Semgrep Rule](https://semgrep.dev/r/javascript.express.security.audit.express-cookie-settings.express-cookie-session-no-expires) - https://owasp.org/Top10/A04_2021-Insecure_Design

TRECHO
app.use(session({ // genid: (req) => { // return genuuid() // use UUIDs for session IDs //}, secret: cookieSecret, // Both mandatory in Express v4 saveUninitialized: true, resave: true /* // Fix for A5 - Security MisConfig // Use generic cookie name key: "sessionId", */ /* // Fix for A3 - XSS // TODO: Add "maxAge" cookie: { httpOnly: true // Remember to start an HTTPS server to get this working // secure: true } … (texto completo no Vulnera)

REFERÊNCIA
https://semgrep.dev/r/javascript.express.security.audit.express-cookie-settings.express-cookie-session-no-expires

---

Média

23. Default session middleware settings: `domain` not set.

Código-fonte (SAST) · Regra javascript.express.security.audit.express-cookie-settings.express-cookie-session-no-domain · CWE-522 · Triagem: Por triar

LOCAL
/src/server.js:78

DESCRIÇÃO
Default session middleware settings: `domain` not set. It indicates the domain of the cookie; use it to compare against the domain of the server in which the URL is being requested. If they match, then check the path attribute next.

RECOMENDAÇÃO
Default session middleware settings: `domain` not set. It indicates the domain of the cookie; use it to compare against the domain of the server in which the URL is being requested. If they match, then check the path attribute next. #### ? Enable cross-file analysis and Pro rules for free at sg.run/pro References: - [Semgrep Rule](https://semgrep.dev/r/javascript.express.security.audit.express-cookie-settings.express-cookie-session-no-domain) - https://owasp.org/Top10/A04_2021-Insecure_Design

TRECHO
app.use(session({ // genid: (req) => { // return genuuid() // use UUIDs for session IDs //}, secret: cookieSecret, // Both mandatory in Express v4 saveUninitialized: true, resave: true /* // Fix for A5 - Security MisConfig // Use generic cookie name key: "sessionId", */ /* // Fix for A3 - XSS // TODO: Add "maxAge" cookie: { httpOnly: true // Remember to start an HTTPS server to get this working // secure: true } … (texto completo no Vulnera)

REFERÊNCIA
https://semgrep.dev/r/javascript.express.security.audit.express-cookie-settings.express-cookie-session-no-domain

---

Média

24. Default session middleware settings: `httpOnly` not set.

Código-fonte (SAST) · Regra javascript.express.security.audit.express-cookie-settings.express-cookie-session-no-httponly · CWE-522 · Triagem: Por triar

LOCAL
/src/server.js:78

DESCRIÇÃO
Default session middleware settings: `httpOnly` not set. It ensures the cookie is sent only over HTTP(S), not client JavaScript, helping to protect against cross-site scripting attacks.

RECOMENDAÇÃO
Default session middleware settings: `httpOnly` not set. It ensures the cookie is sent only over HTTP(S), not client JavaScript, helping to protect against cross-site scripting attacks. #### ? Enable cross-file analysis and Pro rules for free at sg.run/pro References: - [Semgrep Rule](https://semgrep.dev/r/javascript.express.security.audit.express-cookie-settings.express-cookie-session-no-httponly) - https://owasp.org/Top10/A04_2021-Insecure_Design

TRECHO
app.use(session({ // genid: (req) => { // return genuuid() // use UUIDs for session IDs //}, secret: cookieSecret, // Both mandatory in Express v4 saveUninitialized: true, resave: true /* // Fix for A5 - Security MisConfig // Use generic cookie name key: "sessionId", */ /* // Fix for A3 - XSS // TODO: Add "maxAge" cookie: { httpOnly: true // Remember to start an HTTPS server to get this working // secure: true } … (texto completo no Vulnera)

REFERÊNCIA
https://semgrep.dev/r/javascript.express.security.audit.express-cookie-settings.express-cookie-session-no-httponly

Média

25. Default session middleware settings: `path` not set.

Código-fonte (SAST) · Regra javascript.express.security.audit.express-cookie-settings.express-cookie-session-no-path · CWE-522 · Triagem: Por triar

LOCAL
/src/server.js:78

DESCRIÇÃO
Default session middleware settings: `path` not set. It indicates the path of the cookie; use it to compare against the request path. If this and domain match, then send the cookie in the request.

RECOMENDAÇÃO
Default session middleware settings: `path` not set. It indicates the path of the cookie; use it to compare against the request path. If this and domain match, then send the cookie in the request. #### ? Enable cross-file analysis and Pro rules for free at sg.run/pro References: - [Semgrep Rule](https://semgrep.dev/r/javascript.express.security.audit.express-cookie-settings.express-cookie-session-no-path) - https://owasp.org/Top10/A04_2021-Insecure_Design

TRECHO
app.use(session({ // genid: (req) => { // return genuuid() // use UUIDs for session IDs //}, secret: cookieSecret, // Both mandatory in Express v4 saveUninitialized: true, resave: true /* // Fix for A5 - Security MisConfig // Use generic cookie name key: "sessionId", */ /* // Fix for A3 - XSS // TODO: Add "maxAge" cookie: { httpOnly: true // Remember to start an HTTPS server to get this working // secure: true } … (texto completo no Vulnera)

REFERÊNCIA
https://semgrep.dev/r/javascript.express.security.audit.express-cookie-settings.express-cookie-session-no-path

Média

26. Don’t use the default session cookie name Using the default session cookie name can open your app to attacks.

Código-fonte (SAST) · Regra javascript.express.security.audit.express-cookie-settings.express-cookie-session-default-name · CWE-522 · Triagem: Por triar

LOCAL
/src/server.js:78

DESCRIÇÃO

Don’t use the default session cookie name Using the default session cookie name can open your app to attacks. The security issue posed is similar to X-Powered-By: a potential attacker can use it to fingerprint the server and target attacks accordingly.

RECOMENDAÇÃO

Don’t use the default session cookie name Using the default session cookie name can open your app to attacks. The security issue posed is similar to X-Powered-By: a potential attacker can use it to fingerprint the server and target attacks accordingly. #### ? Enable cross-file analysis and Pro rules for free at sg.run/pro References: - [Semgrep Rule](https://semgrep.dev/r/javascript.express.security.audit.express-cookie-settings.express-cookie-session-default-name) - https://owasp.org/Top10/A04_2021-Insecure_Design

TRECHO

app.use(session({ // genid: (req) => { // return genuuid() // use UUIDs for session IDs //}, secret: cookieSecret, // Both mandatory in Express v4 saveUninitialized: true, resave: true /* // Fix for A5 - Security MisConfig // Use generic cookie name key: "sessionId", */ /* // Fix for A3 - XSS // TODO: Add "maxAge" cookie: { httpOnly: true // Remember to start an HTTPS server to get this working // secure: true } … (texto completo no Vulnera)

REFERÊNCIA

https://semgrep.dev/r/javascript.express.security.audit.express-cookie-settings.express-cookie-session-default-name

Média

27. Default session middleware settings: `secure` not set.

Código-fonte (SAST) · Regra javascript.express.security.audit.express-cookie-settings.express-cookie-session-no-secure · CWE-522 · Triagem: Por triar

LOCAL

/src/server.js:78

DESCRIÇÃO

Default session middleware settings: `secure` not set. It ensures the browser only sends the cookie over HTTPS.

RECOMENDAÇÃO

Default session middleware settings: `secure` not set. It ensures the browser only sends the cookie over HTTPS. #### ? Enable cross-file analysis and Pro rules for free at sg.run/pro References: - [Semgrep Rule](https://semgrep.dev/r/javascript.express.security.audit.express-cookie-settings.express-cookie-session-no-secure) - https://owasp.org/Top10/A04_2021-Insecure_Design

TRECHO

app.use(session({ // genid: (req) => { // return genuuid() // use UUIDs for session IDs //}, secret: cookieSecret, // Both mandatory in Express v4 saveUninitialized: true, resave: true /* // Fix for A5 - Security MisConfig // Use generic cookie name key: "sessionId", */ /* // Fix for A3 - XSS // TODO: Add "maxAge" cookie: { httpOnly: true // Remember to start an HTTPS server to get this working // secure: true } … (texto completo no Vulnera)

REFERÊNCIA

https://semgrep.dev/r/javascript.express.security.audit.express-cookie-settings.express-cookie-session-no-secure

Média

28. Checks for any usage of http servers instead of https servers.

Código-fonte (SAST) · Regra problem-based-packs.insecure-transport.js-node.using-http-server.using-http-server · CWE-319 · Triagem: Por triar

LOCAL
/src/server.js:145

DESCRIÇÃO
Checks for any usage of http servers instead of https servers. Encourages the usage of https protocol instead of http, which does not have TLS and is therefore unencrypted. Using http can lead to man-in-the-middle attacks in which the attacker is able to read sensitive information.

RECOMENDAÇÃO
Checks for any usage of http servers instead of https servers. Encourages the usage of https protocol instead of http, which does not have TLS and is therefore unencrypted. Using http can lead to man-in-the-middle attacks in which the attacker is able to read sensitive information. #### ? Enable cross-file analysis and Pro rules for free at sg.run/pro References: - [Semgrep Rule](https://semgrep.dev/r/problem-based-packs.insecure-transport.js-node.using-http-server.using-http-server) - https://nodejs.org/api/http.html#http_class_http_agent - [https://groups.google.com/g/rubyonrails-security/c/NCCsca7TEtY](https://groups.google.com/g/rubyonrails-security/c/NCCsca7TE

TRECHO
```
http.createServer(app).listen(port, () => {
```

REFERÊNCIA
https://semgrep.dev/r/problem-based-packs.insecure-transport.js-node.using-http-server.using-http-server

---

Baixa

29. A CSRF middleware was not detected in your express application.

Código-fonte (SAST) · Regra javascript.express.security.audit.express-check-csurf-middleware-usage.express-check-csurf-middleware-usage · CWE-352 · Triagem: Por triar

LOCAL
/src/server.js:15

DESCRIÇÃO
A CSRF middleware was not detected in your express application. Ensure you are either using one such as `csurf` or `csrf` (see rule references) and/or you are properly doing CSRF validation in your routes with a token or cookies.

RECOMENDAÇÃO
A CSRF middleware was not detected in your express application. Ensure you are either using one such as `csurf` or `csrf` (see rule references) and/or you are properly doing CSRF validation in your routes with a token or cookies. #### ? Enable cross-file analysis and Pro rules for free at sg.run/pro References: - [Semgrep Rule](https://semgrep.dev/r/javascript.express.security.audit.express-check-csurf-middleware-usage.express-check-csurf-middlew - https://www.npmjs.com/package/csurf -

https://www.npmjs.com/package/csrf -
[https://cheatsheetseries.owasp.org/cheatsheets/Cross-Site_Request_Forgery_Prevention_Cheat_Sheet.html](https://cheatsheets
(texto completo no Vulnera)

TRECHO

```
const app = express(); // Web framework to handle routing requests
```

REFERÊNCIA

https://semgrep.dev/r/javascript.express.security.audit.express-check-csurf-middleware-usage.express-check-csurf-middleware-us

Apêndice

METODOLOGIA

O Vulnera não executa as ferramentas de análise: ele importa o relatório que a pipeline do cliente já gera, em SARIF 2.1.0 (Semgrep, CodeQL, SonarQube, Trivy e outras) ou CycloneDX com a seção de vulnerabilidades (SBOM). Cada achado recebe uma impressão digital estável (regra + arquivo + fingerprint da ferramenta, ou pacote + versão + CVE) que permite reconhecê-lo nas importações seguintes, herdar a triagem já feita e calcular o que é novo e o que foi resolvido.

TRIAGEM E PROMOÇÃO

Cada achado é triado por um pentester (confirmado, falso-positivo ou risco aceito). Para virar vulnerabilidade do projeto, o achado é promovido com um vetor CVSS 3.1 revisado por humano: o score da ferramenta é apenas informação, e o score oficial é calculado do vetor confirmado. A vulnerabilidade promovida entra no fluxo de SLA, priorização (VRS) e remediação do Vulnera.

LIMITAÇÕES

A qualidade do resultado é a da ferramenta de origem: o Vulnera não reexecuta regras nem confirma exploração. Achados de dependência indicam uma versão vulnerável presente, não que o trecho vulnerável seja alcançável. Este relatório reflete a importação cmweuumv700b2br4g51ustkhb e a triagem no momento da geração.